Smiles S.A.

RELATÓRIO DE AUDITORIA
N°. 2016-1/3537

Assunto: AIC - COBIT - S.DS2 - Gestão de Serviços Terceirizados de TI

Período da Auditoria:
29/09/2016 a 10/10/2016

Smiles S.A.

ÍNDICE

1 INTRODUÇÃO 3
2 OBJETIVO 3
3 ESCOPO 3
4 CONCLUSÃO 3
5 DETALHAMENTO DE RISCOS E CONTROLES 4
5.1 SDS2.R01.SDS2.C01 4
5.1.1 SDS2.C01 4
5.2 SDS2.R01.SDS2.C02 4
5.2.1 SDS2.C02 4
5.3 SDS2.R02.SDS2.C03 5
5.3.1 SDS2.CO3 5
5.4 SDS2.R02.SDS2.C04 6
5.4.1 SDS2.C04 6
5.5 SDS2.R03.SDS2.C06 7
5.5.1 SDS2.C06 7
5.6 SDS2.R03.SDS2.C07 7
5.6.1 SDS2.C07 7
5.7 SDS2.R04.SDS2.C08 9
5.7.1 SDS2.C08 9

Smiles S.A.

1 INTRODUÇÃO

Avaliar a gestão de serviços terceirizados dos fornecedores da área de TI da Smiles S.A.

2 OBJETIVO

Nosso trabalho teve como objetivo a verificação quanto à efetividade dos controles do Processo do Cobit - Gestão de Serviços Terceirizados de TI para mitigar os riscos vinculados com as atividades desse Processo, no contexto da avaliação da Administração (testes da Administração) para certificação 404-SOX.

3 ESCOPO

Avaliar como a área de TI acompanha as contratações / renovações dos seus fornecedores e avalia a qualidade dos serviços prestados.

4 CONCLUSÃO

Os controles testados, definidos na Matriz de Riscos e Controles, não estão sendo executados de forma efetiva. Nossos testes revelaram pontos e deficiências relevantes que colocam em risco o ambiente de controles gerais da área de TI, tais como:

. O controle sobre a coleta e publicação do indicador não está sendo executado.

. A área de TI não possui um portfólio atualizado contendo todos os fornecedores da área de TI, no qual fiquem registradas as principais informações dos fornecedores e os respectivos gestores.

. Não está sendo realizado um acompanhamento formal e periódico (mensal) dos SLAs para todos os fornecedores da área de TI.

. Falta de formalização para um pagamento efetuado em maio de 2016 ao fornecedor Inmetrics com valores diferentes dos definidos em contrato.

5 DETALHAMENTO DE RISCOS E CONTROLES

5.1 SDS2.R01.SDS2.C01

Descrição Risco:	Dificuldade na identificação de tendências e tomadas de decisão em tempo hábil.

5.1.1 SDS2.C01

Descrição Controle:	É realizada avaliação periódica dos serviços prestado pelos fornecedores chave, verificando se o mesmo está cumprindo todos os requisitos estabelecidos em contrato. Essa avaliação gera um indicador que é publicado trimestralmente pela área de TI.
Efetividade:	Inefetivo

Ponto:

Não conformidade
Verificamos que o controle sobre a publicação do indicador não está sendo executado.

PA-01
Verificamos que o controle S.DS2.C01 está definido no procedimento como mensal, porém a divulgação dos indicadores segundo o controle está definido como trimestral.

Recomendação:

Não conformidade
Recomendamos que o controle de publicação do indicador seja executado conforme definido na matriz de risco deste procedimento (controle S.DS2.C01).

PA-01
Recomendamos que o controle S.DS2.C01 tenha sua frequência de execução alterada no procedimento de trimestral para mensal.

5.2 SDS2.R01.SDS2.C02

Descrição Risco:	Dificuldade na identificação de tendências e tomadas de decisão em tempo hábil.

5.2.1 SDS2.C02

Descrição Controle:	A cada trimestre avaliamos a performance do fornecedor com base nos critérios definidos de contrato, e realizamos uma reunião de acompanhamento.
Efetividade:	Inefetivo

Ponto:

Não conformidade
A área de TI da Smiles não está realizando um acompanhamento formal e periódico (mensal) dos SLAs de todos os seus fornecedores.

Adicionalmente, verificamos que a área de TI não possui um portfólio atualizado contendo todos os fornecedores da área de TI, no qual fiquem registradas as principais informações dos fornecedores, tais como: (i) nome e número do contrato; (ii) Serviço que está sendo prestado; (iii) data de vigência, (iv) níveis de serviços acordados; (v) penalidades em caso de descumprimento; (vi) condições de pagamento e (vii) Gestor responsável, entre outras informações. Ressaltamos que a necessidade de criação e atualização deste portfólio está prevista no item 7.2 do procedimento deste processo.

Recomendação:

Não conformidade
Entendemos que a ausência de uma lista de fornecedores atualizada dificulta o acompanhamento e avaliação dos serviços prestados, se os mesmos estão de acordo com o que foi contratado e ainda estabelecer um histórico de avaliação de cada fornecedor, servindo como base para tomadas de decisão sobre a manutenção ou não do fornecedor. Nesse sentido recomendamos que seja elaborada e atualizada regularmente uma planilha contendo todos os fornecedores de TI.
Recomendamos ainda que os SLAs de todos os fornecedores críticos da área de TI sejam acompanhados mensalmente pela área de TI, a fim de garantir que os níveis de serviços estão sendo cumpridos e estão aderentes aos requisitos do negócio.

5.3 SDS2.R02.SDS2.C03

Descrição Risco:	Não avaliação dos fornecedores e do cumprimento das obrigações contratuais, fiscais, legais e trabalhistas e previdenciárias.

5.3.1 SDS2.CO3

Descrição Controle:	Realizamos o acompanhamento do trabalho prestado pelo fornecedor, verificando se o mesmo está cumprindo todos os requisitos estabelecidos em contrato.
Efetividade:	Inefetivo

Ponto:

Não conformidade
Verificamos que o controle (S.DS2.C03) não está sendo executado pois não foram produzidas atas de reuniões para formalizar o acompanhamento dos serviços prestados pelos fornecedores.

Adicionalmente, em decorrência da não conformidade apontada no controle S.DS2.C02, referente a falta de uma lista atualizada contendo os principais dados contratuais de todos os fornecedores da área de TI e a ausência de um acompanhamento formal e periódico (mensal) dos SLAs, consideramos este controle inefetivo.

PA-02 Verificamos que o controle S.DS2.C03 está definido como sob demanda. Entendemos que o acompanhamento referente ao serviço prestado pelo fornecedor deve ser executado mensalmente.

Recomendação:

Não conformidade

Vide recomendação descrita para o controle S.DS2.C02.

PA-02 Recomendamos que o controle S.D2.C03 tenha sua frequência de execução alterada de sob demanda para mensal.

5.4 SDS2.R02.SDS2.C04

Descrição Risco:	Não avaliação dos fornecedores e do cumprimento das obrigações contratuais, fiscais, legais e trabalhistas e previdenciárias

5.4.1 SDS2.C04

Descrição Controle:	Cada Gerência de TI, conforme seu escopo é responsável por realizar o acompanhamento e formalização de acordos prestados e validar se todos foram atendidos.
Efetividade:	Inefetivo

Ponto:

Não conformidade
Verificamos que o controle (S.DS2.C04) não está sendo executado, uma vez que não existe formalização trimestral dos acompanhamentos efetuados.

Adicionalmente, em decorrência da não conformidade apontada no controle S.DS2.C02, referente a falta de uma lista atualizada contendo os principais dados contratuais de todos os fornecedores da área de TI, consideramos este controle inefetivo.

Recomendação:

Não conformidade
Vide recomendação descrita para o controle S.DS2.C02.

5.5 SDS2.R03.SDS2.C06

Descrição Risco:	Ausência/falta de cumprimento do serviço conforme acordado, possibilitando pagamento do serviço não realizado

5.5.1 SDS2.C06

Descrição Controle:	Ao verificar que um contrato está a vencer, a equipe de Governança de TI, o aciona o gestor responsável pelo contrato para que o mesmo retorne se haverá renovação ou não. Havendo renovação, o gestor é responsável por analisar os critérios de SLAs (sendo este aplicável ou não a revisão de métricas contratuais) financeiros, estratégicos, entre outros.
Efetividade:	Inefetivo

Ponto:

Não conformidade
A área de TI da Smiles não está realizando uma análise formal e periódica com a finalidade de avaliar se os serviços prestados por todos os seus fornecedores estão de acordo com os níveis de serviços estabelecidos em contrato e não realizam a revisão dos SLAs estabelecidos, quando da ocorrência de renovação de contrato.

Adicionalmente, em decorrência da não conformidade apontada no controle S.DS2.C02, referente a falta de uma lista atualizada contendo os principais dados contratuais de todos os fornecedores da área de TI, consideramos este controle inefetivo.

Recomendação:

Não conformidade
Vide recomendação descrita para o controle S.DS2.C02.

5.6 SDS2.R03.SDS2.C07

Descrição Risco:	Ausência/falta de cumprimento do serviço conforme acordado, possibilitando pagamento do serviço não realizado

5.6.1 SDS2.C07

Descrição Controle:	O pagamento é realizado através de entregas, quando não ocorrer a entrega ou entrega parcial, o fornecedor deverá ser penalizado conforme o contrato.
Efetividade:	Inefetivo

Ponto:

Não conformidade
Conforme citado na não conformidade apontada no controle S.DS2.C02 (NCONF-02), não existe uma lista atualizada contendo os principais dados contratuais de todos os fornecedores da área de TI, bem como não está sendo realizado um acompanhamento formal e periódico (mensal) dos SLAs dos fornecedores da área de TI. A ausência desses dois controles dificulta a

avaliação por parte do gestor do contrato se o serviço está sendo prestado de acordo com os níveis de serviço estabelecidos em contrato.

Verificamos que o pagamento efetuado em maio de 2016 para o fornecedor Inmetrics foi efetuado com o valor hora/homem diferente do valor definido em contrato. O pagamento foi aprovado pelo gestor do contrato, mas não consta na aprovação nenhuma justificativa para realização do pagamento com o valor divergente.

PA-03 Verificamos que as planilhas disponibilizadas pelos fornecedores referentes as horas trabalhadas não constam o tipo de perfil do profissional que realizou tal atividade. Dessa forma, dificulta a avaliação / validação por parte do gestor do contrato se o valor cobrado pelo fornecedor (hora/homem) está considerando corretamente as categorias profissionais alocadas nos trabalhos (Júnior, Pleno ou Sênior).

PA-04 Verificamos que o fornecedor Infostrategy teve seu pagamento efetuado, para ao mês de Maio, referente uma Proposta Comercial executada com apenas um "de acordo" por e-mail, não havendo a necessidade de assinatura das partes**.**

Recomendação:

Não conformidade
Vide recomendação descrita para o controle S.DS2.C02.

Recomendamos que sempre que houver um acordo entre o gestor do contrato e o fornecedor, para pagamento de valores divergentes dos previstos em contrato, que seja feita a formalização desse acordo preferencialmente através de termo aditivo ao contrato.

PA-03 Recomendamos que nas planilhas de horas trabalhadas dos fornecedores seja incluído o tipo (perfil) do profissional alocado pelo fornecedor na execução do trabalho, conforme previsto em contrato. De posse da informação do tipo de profissional alocado o gestor do contrato deve conferir se o valor cobrado está em conformidade com o estabelecido em contrato, bem como se o profissional alocado foi o mesmo demandado pela área de TI.

PA-04 Recomendamos que para toda atividade realizada, que se tenha assinatura nas Propostas comerciais dos gestores e do jurídico.

5.7 SDS2.R04.SDS2.C08

Descrição Risco:	Interrupção do serviço, devido a descontinuidade do fornecedor

5.7.1 SDS2.C08

Descrição Controle:	A cada trimestre avaliamos a performance do fornecedor com base nos critérios definidos de contrato, e realizamos uma reunião de acompanhamento.
Efetividade:	Inefetivo

Ponto:

Não conformidade
Verificamos que este controle (S.DS2.C08) é semelhante ao controle S.DS2.C02 cujo resultado foi inefetivo.

Recomendação:

Não conformidade
Vide recomendação descrita para o controle S.DS2.C02.

Smiles S.A.

Envolvidos na Auditoria:

_____
Delio Goldner
Revisor

_____
Marcio Mendes
Revisor

_____
Andre Luis Gonçalves Fernandes
Auditor Responsável

_____
Juliana Genio Dantonio
Aprovador 1a Alçada